

인턴 · 초급 개발자 교육자료

서비스, 만들고 배포하고 돈 벌기 전에 — 꼭 알아야 할 법·규제

대한민국에서 웹·앱 서비스를 개발·운영할 때의 유의점 총정리

개발·배포(개인정보·보안)

수익 창출

채팅·데이팅앱 운영

오픈소스·AI 코드

기준 시점 2026-07 · 본 자료는 법률자문이 아닌 교육용 개요입니다 — 실제 적용 전 최신
법령·전문가 확인 필수

시작하며 — 왜 개발자가 법을 알아야 하나

서비스는 코드만으로 굴러가지 않습니다. **이용자의 개인정보를 다루는 순간, 돈을 받는 순간, 사람들을 연결하는 순간** 각각 법적 의무가 생깁니다. 이것 모르고 지나치면 **과태료·과징금·서비스 중단·형사책임**은 물론, 회사 평판까지 무너질 수 있습니다. 오늘은 "무심코 지나치기 쉬운데 실무에서 꼭 챙겨야 하는 것"을 네 갈래로 정리합니다.

반드시 먼저 읽어주세요 (면책 고지)

이 자료는 법률자문이 아니라 교육용 개요입니다. 큰 그림과 "무엇을 챙겨야 하는지 감"을 잡는 것이 목적입니다.

- 법은 자주 바뀝니다. 특히 개인정보보호법은 2026-09-11 대규모 개정 시행이 임박해 있습니다(본문 참조). 이 문서는 2026년 7월 기준입니다.
- 구체적 수치·기준은 시점에 따라 달라질 수 있습니다. "확인 필요"로 표시한 곳은 반드시 최신 원문으로 재확인하세요.
- 실제 적용·중요한 의사결정 전에는 최신 법령 원문(law.go.kr)과 소관 기관 안내를 확인하고, 필요하면 변호사·노무사·세무사 등 전문가와 상의하세요.

이 자료의 구성

장	주제	한 줄 요지
1	개발·배포 시 (개인정보·보안)	이용자 정보를 다루면 규모와 무관하게 지켜야 할 것
2	수익을 창출할 때	신고·결제·세금·환불 — 돈을 받으면 생기는 의무
3	채팅·데이팅앱 운영	사람을 연결하는 서비스의 특별한 안전·규제 의무
4	오픈소스·타 코드·AI 코드 활용	라이선스·저작권·보안·기밀 — 코드의 출처 관리

읽는 법

각 항목에 **높음** / **중간** / **낮음** 으로 **리스크·우선순위**를 표시했습니다. 바쁘면 **높음**부터 보세요. 근거 법령·기관과 출처는 각 장 끝과 마지막 "출처" 절에 정리했습니다.

1 서비스 개발·배포 시 — 개인정보와 보안

결론부터 (자주 위반하는 순서)

- ① 동의·최소수집 설계 → ② 개인정보 처리방침 게시 → ③ 암호화·HTTPS·접속기록 등 안전조치 → ④ 주민등록번호 수집 금지 → ⑤ 유출 시 72시간 대응. 핵심: 이 의무들은 회사 규모와 무관하게 '개인 정보를 처리하는 모든 자'에게 적용됩니다. "우린 작으니까 괜찮다"는 통하지 않습니다.

Tier 1 — 거의 모든 서비스에 적용 (위반 빈도 최상)

① 수집·이용 동의 + 최소수집 원칙 **높음**

- 개인정보 수집 시 **4가지를 반드시 고지**하고 동의받기: (1) 이용 목적, (2) 수집 항목, (3) 보유·이용 기간, (4) 동의 거부 권리와 거부 시 불이익.
- 회원가입에서 **필수 항목과 선택 항목을 분리**. 선택 항목에 동의 안 했다고 **가입을 막으면 위법**.
- 체크박스 하나로 전부 받는 '**포괄 동의**' 금지 → 목적별로 구분. 목적에 필요한 **최소한만** 수집(입증 책임은 회사에 있음).

근거: 개인정보보호법 제15·16·22조 (국가법령정보센터)

② 개인정보 처리방침 수립·공개 **높음**

웹/앱에 "**개인정보 처리방침**"을 상시 접근 가능하게 노출(보통 화면 하단 고정 링크). 법정 항목(처리 목적·기간, 제3자 제공, 파기, 위탁, 정보주체 권리, **개인정보 보호책임자 연락처**, 쿠키 등 자동수집 및 거부 방법 등)을 포함해야 합니다.

자주 하는 실수

'이용약관'과 '개인정보 처리방침'은 다른 문서입니다. 둘을 합치지 말고 각각 두세요. 처리방침 없이 서비스를 열면 과태료 대상입니다.

근거: 개인정보보호법 제30조

③ 안전조치 — 개발자가 코드로 책임지는 부분 **높음**

해야 할 것	구체적으로
비밀번호 저장	복호화 불가능한 일방향 해시 (bcrypt/PBKDF2 등). 평문·양방향 암호화 저장 금지
민감정보 암호화	고유식별정보(주민·여권·운전면허·외국인등록번호)·비밀번호·바이오정보는 저장·전송 시 암호화
전송 구간 암호화	로그인·인증·민감정보 전송은 HTTPS/TLS 적용(안전조치 기준의 실질적 이행 수단)
접속기록(로그) 보관	최소 1년 . 단 5만 명 이상 처리·민감/고유식별정보 처리·기간통신사업자는 2년 . 위·변조 방지
접근통제	권한 최소화, 계정별 권한 관리, 침입 차단·탐지

근거: 개인정보보호법 제29조 + 「개인정보의 안전성 확보조치 기준」 고시(개정 잦음 → 최신본 확인)

④ 주민등록번호·민감정보 처리 제한 **높음**

- **회원가입에 주민번호를 받지 마세요.** 원칙적으로 수집 금지입니다. 본인확인이 필요하면 **대체수단**(휴대폰 본인확인·아이핀·공동인증서·신용카드)을 쓰세요.
- 민감정보(건강, 성생활·성적지향, 사상·신념, 정치적 견해, 유전·생체인식정보, 범죄경력 등)는 **별도 동의** 또는 법령 근거가 있어야 처리 가능.

근거: 개인정보보호법 제23조(민감정보)·제24조의2(주민번호), 정보통신망법 제23조의2·3

⑤ 개인정보 유출 시 — 72시간 대응 **높음**

유출 사고 시 (법적 의무)

- **정보주체 통지:** 유출 인지 후 **72시간 이내**(지체 없이). 유출 항목·시점·경위, 피해 최소화 방법, 대응 조치·구제절차, 담당 연락처를 알림.
- **당국 신고:** 72시간 이내, 접수기관 **한국인터넷진흥원(KISA)**, 온라인 brss.pipc.go.kr. 신고 대상: **1,000명 이상** 유출 / 민감·고유식별정보 유출 / 외부의 불법 접근에 의한 유출 **중 하나라도** 해당 시.
- **미리 유출 대응 플레이북**(로그 확보·통지문 템플릿·신고 담당자)을 준비해 두세요.

근거: 개인정보보호법 제34조, 시행령 제39-40조 (개인정보보호위원회·KISA). ※ 건수·기한은 2026 개정으로 확대 가능 → 확인 필요

Tier 2 — 해당 기능이 있으면 반드시

기능/상황	핵심 의무	근거
마케팅 알림(문자·메일·푸시) 중간	사전 수신동의(opt-in) 후 전송. 매 건 "(광고)" 표시 + 무료 수신거부 방법 명시. 야간(21시~익일 8시)은 별도 동의(이메일은 예외). 2년마다 수신동의 재확인	정보통신망법 제 50조 (KISA·방통위)
만 14세 미만 아동 중간	법정대리인(보호자) 동의 필수. 가입 플로우에 연령 확인 → 미만이면 보호자 동의로 분기	개인정보보호법 제22조의2
데이터 보관 중간	목적 달성·기간 경과로 불필요해지면 지체 없이 파기. 탈퇴/만료 데이터 자동 삭제 구현	개인정보보호법 제21조
해외 클라우드·SaaS 사용 중간	개인정보 국외 이전은 원칙적으로 별도 동의/고지. 해외 리전 저장·해외 SaaS가 해당. 처리방침에 공개	개인정보보호법 제28조의8
조직 차원 낮음	개인정보 보호책임자(CPO) 지정(소규모는 대표가 간주) 및 처리방침에 연락처 공개	개인정보보호법 제31조

Tier 3 — 특정 서비스 유형·규모

유형	핵심	근거/기관
위치기반 서비스(지도·배달·주변검색) 중간	위치기반서비스사업 → 방송통신위원회 신고. 개인위치정보는 약관 명시 + 동의(14세 미만 법정대리인). ※ 인허가 방식은 원문 확인	위치정보법 (방통위)
웹 접근성 중간	장애인이 동등하게 접근하도록 정당한 편의 제공 (대체텍스트·키보드 접근·명도대비 등 KWCA). 미제공은 차별 → 시정·배상 가능	장애인차별금지법 제21조
본인확인 필요 시 낮음	주민번호 대신 본인확인기관 연계 (휴대폰·아이핀·공동인증서·신용카드)	정보통신망법 제23조의2·3
대규모 사업자 낮음	매출·이용자 일정 규모 이상은 ISMS(-P) 인증 의무 . 소규모는 비대상이나 ISMS-P 자율 취득 권장	정보통신망법 제47조 (KISA)

임박한 큰 변화 — 개인정보보호법 개정(2026-09-11 시행) · 확인 필요

약 두 달 뒤 시행 예정이며 실무 영향이 큼니다(아직 시행 전, **시행령·고시 확정 중**이라 2차 출처 기반):

- CPO 책임 강화**(대표를 최종책임자로 명시, 일정 규모는 이사회 의결 + 개인정보위 신고)
- 유출 통지 요건 확대**(확정 유출 전 '우려' 단계 통지 논의)
- 징벌적 과징금 상향**(중대·반복 위반 시 전체 매출액 3% → **10% 이내** 특례)
- 정보보호 인증 의무화 신설**(2027-07-01 적용 예정)

→ 정확한 요건·대상은 **시행령·고시 확정 후 반드시 재확인**하세요.

2 서비스로 수익을 창출할 때

결론부터 — 개발자가 먼저 알 5가지

1. "돈을 받는 순간" 규제가 시작된다. 무료와 유료는 완전히 다른 법의 세계. 수익모델(판매·구독·광고·인앱)마다 적용 법이 갈린다.
2. 개인은 카드결제를 직접 못 받는다. 반드시 PG(결제대행)를 낀다 — 불편이 아니라 법(전자금융거래법) 구조다.
3. 온라인 판매 = 사업자등록 + 통신판매업 신고가 기본 세트(소규모는 신고 면제 가능하나 세금은 별개로 살아있음).
4. UI/UX가 곧 법 위반이 될 수 있다. 해지 숨기기·몰래 자동결제 전환·협찬 미표시는 개발자가 만든 화면에서 나오는 리스크(다크패턴 규제).
5. 미성년자 결제는 원칙적으로 취소 가능 — 결제 UI 설계에 이 리스크를 반드시 반영.

순위	영역	주요 관할	리스크	즉시 할 일
1	통신판매업·전자상거래법	공정위/시·군·구	높음	신고번호·사업자정보 표시, 청약철회 UI
2	결제(전자금융거래법)	금융위/금감원	높음	PG 연동, 에스스로 표시
3	구독·다크패턴	공정위	높음	자동갱신 고지·쉬운 해지 UI
4	앱 인앱결제	과기정통부·방통위	중간	수수료 반영 가격설계
5	미성년자 결제	(민법)	중간	법정대리인 동의·환불 프로세스
6	세금	국세청	중간	사업자등록, 세금계산서/현금영수증
7	광고 수익	공정위/개인정보위	중간	협찬 표시, 행태정보 동의

④ 통신판매업 신고 + 전자상거래법 판매자 의무 높음

- 온라인으로 반복 판매하면 **통신판매업 신고**(관할 시·군·구, [정부24](#) 온라인). **면제**: 직전년도 거래 50회 미만 또는 간이과세자(공정위 고시, 청약철회분 제외). ※ 오픈마켓이 자체 정책으로 신고번호를 요구하기도 함.
- 상시 표시 의무(§13): 상호·대표자·주소·전화·**사업자등록번호**·**통신판매업 신고번호**·약관.
- **청약철회(§17)**: 원칙 **공급받은 날/계약일**부터 7일 이내. 표시·광고와 다르거나 하자면 공급받은 날부터 3개월/안 날부터 30일. (즉시 소비·사용한 디지털 재화는 철회 제한 가능)
- **환불(§18)**: 반환받은 날부터 **3영업일** 이내 현금.

흔한 오해 정정 (확인 필요)

통신판매업 미신고는 형사 "벌금"이 아니라 행정 "과태료"입니다(블로그에 흔한 "3천만원 벌금"은 부정확). 실제 금액 구간은 위반 유형·개정 시점에 따라 500만~3천만 원으로 갈려 law.go.kr 현행본 확인이 필요합니다. 더 큰 실무 리스크는 공정위 시정조치 → 불이행 시 영업정지·과징금입니다.

근거: 전자상거래법 제12·13·17·18·20조 (법제처), 통신판매업 신고 면제 고시 (공정위·소비자24)

② 결제 — 왜 개인이 직접 카드결제를 못 받나 **높음**

- 여러 판매자의 카드결제를 모아 승인·정산하는 행위는 전자금융거래법상 전자지급결제대행업(PG)이라 금융위 등록이 필요 → 그래서 개발자는 직접 카드번호를 받지 말고 등록된 PG사(토스페이먼츠·KG이니시스·NHN KCP 등)에 하위가맹점으로 연동합니다(PCI-DSS 보안 리스크도 회피).
- 에스크로/구매안전: 배송 전에 현금·계좌이체로 선결제받는 통신판매는 결제대금예치(에스크로)·피해보상보험 등을 제공·선택하게 해야 함(신용카드·배송불요 디지털재화는 예외). 기준 금액은 **확인 필요**.

근거: 전자금융거래법 제28조 등, 전자상거래법 제13·24조 (금융위). 참고: 2024 '티메프' 사태 후 PG 정산자금 별도관리 개정 추진 중

③ 구독·정기결제 & 다크패턴 **높음** (규제 신설 — 개발자 UI 직결)

- 공정위가 **눈속임 설계(다크패턴)**를 직접 규율(개정 전자상거래법, 2025-02-14 시행으로 확인 — 원문 대조 권장). 예: 무료→유료 전환·정기결제 증액 시 30일 이내 동의 + 해지 방법 고지, 반복 팝업 강요 금지, 첫 화면에 총금액 표시(숨은 가격 금지).
- 개발자: 자동갱신 사전 고지 + 동의 UI, 결제일·금액·해지방법 명확 표시, "가입만큼 쉬운 해지", 무료체험 종료·자동결제 예정 사전 안내.

근거: 개정 전자상거래법 (공정거래위원회). 과태료·영업정지 부과기준은 확인 필요

④ 앱 인앱결제 **중간**

- 구글/애플은 디지털 재화·구독에 자사 인앱결제(IAP)를 원칙 요구, 표준 수수료 ~30%(소규모·구독 2년차 등 15% 프로그램). **실물 상품·오프라인 서비스는 IAP 대상이 아님**(별도 PG 가능) — 이 구분이 중요.
- 국내 '인앱결제 강제금지법'(전기통신사업법 제50조의9, 2021.9 시행, 세계 최초): 앱마켓의 특정 결제 방식 강제·부당 지연·삭제 금지. 함정: 외부결제를 허용해도 ~26% 수수료가 붙어 실익이 제한적.

확인 필요 (변동성 큼)

방통위가 예고한 인앱결제 위반 과징금(2023.10 **구글 약 475억·애플 약 205억 "예고"치**)의 최종 부과액·시점, 그리고 구글/애플의 최신 수수료율·소규모 프로그램 조건은 유동적이므로 각사 공식 정책·기관 발표로 재확인하세요.

⑤ 미성년자 결제 **중간**

민법 제5조상 미성년자(만 19세 미만)가 법정대리인 동의 없이 한 결제는 취소 가능 → 환불 대상. 예외: 용돈 등 처분 허락 재산 범위, 미성년자가 속임수로 성년/동의를 가장한 경우(§17). 개발자: **법정대리인 동의 절차·결제 한도·환불 프로세스** 마련. 즉시 소비되는 디지털 재화라도 미성년 취소권은 청약철회와 별개로 인정됩니다(사후 소송보다 기술적 차단이 효과적).

근거: 민법 제5·17조 (법제처)

⑥ 세금 중간

- **사업자등록**: 사업 개시일부터 **20일 이내**(홈택스). 온라인 판매도 필수.
- **부가가치세**: 일반과세 10%(연 2회 신고), 간이과세 낮은 부가율(연 1회). **간이과세 기준: 2024-07-01부터 직전연도 공급대가 1억 400만 원 미만**. 연 매출 4,800만 원 미만이면 부가세 **납부 면제**(신고 의무는 유지).
- **소득세**: 매년 5월 종합소득세 신고. 개발자: PG 정산·매출 데이터 보관, **세금계산서·현금영수증**을 결제 플로우에 연동.

근거: 부가가치세법·소득세법 (국세청). 부가율·납부면제·현금영수증 의무발행 업종·전자세금계산서 의무 기준은 홈택스에서 확인 필요

⑦ 광고 수익 중간

- **표시광고법**: 거짓·과장·기만·부당비교·비방 광고 금지(시정명령·과징금).
- **뒷광고**(대가성 미표시): 경제적 이해관계(현금·무상 제공·수수료 등)가 있으면 **"광고/유료광고 포함"**을 **명확하고 근접한 위치에 표시**. 본문 중간·"더보기" 안 표시는 부적절(제재는 주로 광고주).
- **맞춤형(행태) 광고**: 쿠키·광고식별자 등 행태정보 수집 시 개인정보보호법에 따라 **고지·동의**(개인정보위·방통위 가이드라인). 아동 대상은 더 엄격.

근거: 표시광고법, 추천·보증 표시·광고 심사지침 (공정거래위원회), 개인정보보호법 (개인정보위)

3 채팅·데이팅·랜덤채팅 서비스 운영

먼저 프레임을 바로잡기 — 규제는 "앱 종류"가 아니라 "기능"으로 발동

"우린 단순 채팅앱이라 데이팅 규제와 무관"은 위험한 오해입니다. 아래 기능 중 하나라도 있으면 해당 규제가 그대로 적용됩니다.

1. 불특정 이용자 간 게시·전송 → 불법촬영물 유통방지 의무 + 정보통신망법 삭제/임시조치
2. 위치 기반 매칭 → 위치정보법(방통위 신고 + 별도 동의)
3. 유료 재화(하트·코인) 결제 → 전자상거래법 + 미성년자 계약 취소 리스크

① 불법촬영물 등 유통방지 사전조치 ('n번방 방지법') **높음** (리스크 최상)

- 근거: 전기통신사업법 제22조의5, 시행령 제30조의6, 방통위 고시. 대상: 성폭력처벌법상 촬영물·허위영상물(딥페이크), 아동·청소년성착취물.
- 적용 대상(사전조치의무사업자): 부가통신사업자 중 전년 매출 10억 원 이상 또는 직전 3개월 일평균 이용자 10만 명 이상이면서 SNS·커뮤니티·대화방 등을 제공하는 사업자. (정확한 임계값·대상 목록은 시행령 최신본 확인 필요)
- 2026-07-01부터 기술적·관리적 조치 대상이 동영상 → 이미지 파일까지 확대 시행(최신 변화, 반드시 반영).
- 요구 조치: 상시 신고·삭제 기능, 필터링(방심위 심의 DB의 특징정보와 비교·식별해 게재 차단), 검색결과 제한, 사전 경고문구, 신고·처리 기록 보관 + 투명성 보고.

근거: 전기통신사업법 (법제처), 방통위·방심위. ※ 사전검열 논란으로 헌법소원이 제기된 바 있어 최종 결론은 확인 필요

② 청소년 보호 **높음** (랜덤채팅앱의 핵심 규제)

- 청소년보호법: 연령 확인, 청소년유해매체물 표시·광고 제한.
- 여성가족부 랜덤채팅앱 규제(2020 고시): ①실명/휴대폰 인증 ②대화 저장 ③신고 기능 — 이 3가지 안전장치 중 하나라도 없으면 앱이 '청소년유해매체물'로 지정되어 성인만 이용 가능. (현행 유효성·개정 여부 확인 필요)
- 배경: 랜덤채팅이 조건만남·디지털 성범죄 유인 경로로 악용 → 규제 강화. 성인전용이면 성인인증·유해매체물 표시·미성년 접근 차단.

근거: 청소년보호법 (법제처), 여성가족부 고시

③ 본인확인 / 성인인증 **높음**

청소년유해매체물 제공 시 나이·본인 확인 의무. 주민등록번호는 원칙 수집 금지 → 본인확인기관 대체수단(휴대폰·아이핀·공동/금융인증서·신용카드) 사용.

데이터 최소화 — 성인인증에 주민번호는 필요 없다

"성인 확인"의 목적에는 주민번호 자체가 아니라 성인 여부(Y/N) 결과값만 있으면 충분합니다. 원본 식별정보(주민번호 등)는 저장하지 말고 결과값만 보관하도록 설계하세요. "이 데이터를 꼭 받아야 하나?"를 먼저 자문하는 것이 최선의 보안입니다.

근거: 정보통신망법·청소년보호법 (법제처), KISA. 세부 조문·발동 요건은 확인 필요

④ 콘텐츠 모더레이션·신고체계·운영자 책임 **높음**

- 정보통신망법 제44조의2(권리침해 정보 삭제요청·임시조치, 다툼 시 최대 30일 접근 차단), 제44조의7(불법정보 유통금지).
- 운영자가 알고도 방치하면 방조 책임으로 이어질 수 있음 → 신고 → 검토 → 조치(삭제·차단·임시조치) → 통지 → 이의 전 과정을 시스템화하고 로그를 남기세요.
- 이용자 제재(경고·정지·영구차단·재가입 제한) 정책을 약관에 명시·일관 적용. 성착취물 신고 채널을 눈에 띄게(디지털성범죄피해자지원센터·경찰 연계). 자동 필터 + 사람 검수 병행.

근거: 정보통신망법 제44조의2·7 (법제처), 방심위·방통위

⑤ 개인정보·민감정보·위치정보 **높음**

- 민감정보(성적 지향·성생활·건강 등)는 원칙 처리 금지 → 다른 동의와 분리된 별도 동의가 있어야 처리 (개인정보보호법 제23조). 데이팅앱의 이상형·성향 프로필이 해당할 수 있음.
- 위치 매칭: 위치기반서비스사업 방통위 신고 + 개인위치정보 수집·이용·제공 각각 별도 동의·약관 명시 (소규모·1인 창조기업은 보고로 신고 간주 완화).
- 대화·프로필 데이터는 보유기간을 정하고 지체 없이 파기(제21조).

추론적 재식별 위험 — 결합에 주의

개별 항목을 마스킹해도 위치 + 성적 지향 + 접속 시간대 + 프로필이 결합되면 개인이 특정될 수 있습니다(추론적 재식별). 매칭 로그·분석 데이터를 결합·보관할 때 이 위험을 비판적으로 검토하고, 수집 자체를 최소화하는 설계를 우선하세요.

근거: 개인정보보호법 제23·21조 (개인정보위), 위치정보법 (방통위)

⑥ 안전 — 로맨스스캠·사기·성착취 예방 **중간** (권고 성격, 방치 시 논란)

- 로맨스스캠은 통신사기피해환급법 대상이 아니어서 사후 환급이 어렵다 → 사전 예방이 사실상 유일한 방어선.
- 가입/프로필 검증(이메일·휴대폰 인증, 프로필 사진 역검색·중복 탐지), 행동 탐지(신규 계정의 외부 메신저 유도·송금/투자 유도·외부 링크 패턴 경고·차단), 인앱 경고·교육, 피해 대응 안내(대화·송금내역 보존, 경찰 112·사이버범죄 신고 ecrm).

⑦ 유료 아이템(하트·코인) 결제 **중간**

전자상거래법상 통신판매업 신고·표시·청약철회 적용. 디지털 콘텐츠는 원칙 청약철회 가능하나 일부라도 사용하면 철회 불가가 될 수 있어 환불·청약철회 정책을 결제화면에 명확히 고지. 미성년자 결제 방지(성인/법정대리인 동의 확인, 결제 한도)와 앱마켓 환불 프로세스 정합성 유지. (자세한 결제 규제는 2장 참조)

확인 필요 — 규제기관 명칭

2026년 현재 규제·심의 기구가 "방송미디어통신위원회 / 방송미디어통신심의위원회" 명칭으로 개편된 정황이 있습니다(과거 방송통신위원회·방송통신심의위원회). 신고·문의 전 소관 기관의 현행 명칭·창구를 확인하세요.

우선순위	항목	핵심 근거	착수 시점
1	불법촬영물 유통방지	전기통신사업법 §22의5	규모 요건 충족 시 최우선
2	청소년 보호(연령·유해매체물)	청소년보호법·여가부 고시	출시 전 필수
3	본인확인/성인인증	정보통신망법	출시 전 필수
4	모더레이션·방조 책임	정보통신망법 §44의2·7	출시 전 필수
5	개인정보·위치·민감정보	개인정보보호법·위치정보법	설계 단계부터
6	스캠·성착취 예방	(권고)+아청법	운영 중 지속

4 오픈소스·타 코드·AI 생성 코드 활용

결론부터 — 이 5가지만 지켜도 리스크 90% 감소

1. 사내 소스·기밀·개인정보를 외부 AI(ChatGPT 등)·공개 웹에 붙여넣지 마라. (되돌릴 수 없는 유출)
2. GPL/AGPL 코드를 제품에 넣기 전 반드시 팀에 확인하라. (내 회사 소스 공개 강제 위험)
3. AI가 만든 코드를 '출처 없는 안전한 내 코드'로 착각하지 마라. (라이선스 오염·보안 취약·저작권 미확정)
4. Stack Overflow·블로그·전 직장 코드를 그대로 복붙하지 마라. (저작권 침해)
5. MIT·Apache 같은 관대한 라이선스도 고지 의무가 있다. 라이선스·저작권 문구를 지우면 그것도 위반.

한 줄 원칙: "사내 사용"은 대체로 관대하지만, "배포(제품 출시)"와 "SaaS(네트워크 서비스)"의 순간 의무가 폭발한다.

4-1. 오픈소스 라이선스 스펙트럼

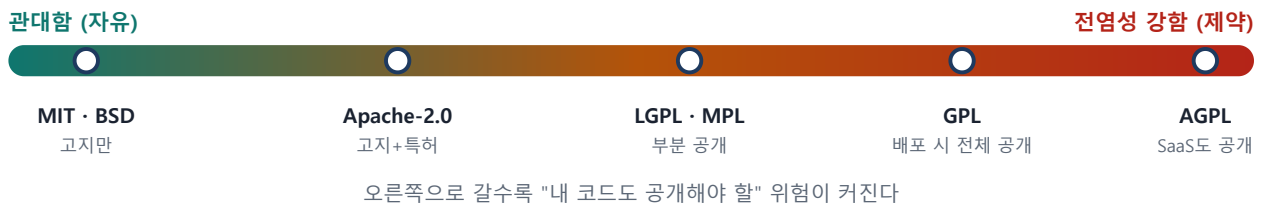


그림. 관대함 ↔ 전염성 스펙트럼 — 오른쪽일수록 내 코드 공개 위험 ↑

라이선스	유형	핵심 의무	내 비공개 코드와 결합·배포	리스크
MIT · BSD	관대	저작권·라이선스 고지 포함	가능	낮음
Apache-2.0	관대	고지 + NOTICE 유지 + 변경 명시. 특허 사용권 부여	가능	낮음
LGPL	약한 카피레프트	동적 링크 시 앱 본체 비공개 가능(교체 가능해야)	조건부 가능(동적 링크)	중간
MPL-2.0	약한 카피레프트	수정한 파일의 소스만 공개	가능(다른 파일 비공개)	중간
GPL	강한 카피레프트	배포 시 결합물 전체를 GPL로 공개	배포 시 불가(사내 사용은 무방)	높음
AGPL	강한 + 네트워크	GPL + 네트워크 서비스 제공만 해도 소스 공개	사실상 불가(SaaS 치명적)	높음

4-2. 우선순위별 유의점

① 회사 기밀·소스·개인정보를 외부 AI/웹에 입력 **높음** (가장 흔하고 되돌릴 수 없음)

- 외부 생성형 AI에 넣은 내용은 **제공사 서버로 전송**되고 소비자용 기본 설정에선 **학습에 쓰일 수** 있습니다. 한 번 나가면 회수 불가.
- 실제 사례: **삼성전자(2023)** — 엔지니어가 반도체 소스·기밀 회의록을 ChatGPT에 입력 → 유출 → 사내 생성형 AI 전면 금지로 이어짐.
- 개별 조각은 익명이어도 **여러 정보가 결합되면 기술·신원이 추론(재식별)**될 수 있어 마스킹만으로 부족.

해야 할 것

① 기밀·소스·개인정보는 **외부 AI 입력 금지**. "이걸 꼭 외부에 처리시켜야 하나?"부터 자문(데이터 최소화), 필요하면 **더미 값으로 치환**해 질문. ② 회사가 승인한 **엔터프라이즈 등급 도구만** 사용(입력이 학습에 안 쓰이도록 계약 보장). 무료 개인계정과 구분. ③ 커밋 전 **비밀정보 스캐닝**(gitleaks 등)으로 API 키·토큰 유출 차단. ④ "이번 한 번만"·"내부용" 예외를 두지 마라.

② 카피레프트(GPL/LGPL/AGPL)의 '전염성' **높음** (파괴력 최대)

- GPL 코드를 내 코드와 결합해 **배포**하면 내 코드까지 **GPL로 소스 공개**해야 합니다(정적·동적 링크 모두 결합물로 보는 것이 FSF 해석).
- **트리거는 '배포'**: 사내에서만 쓰고 내보내지 않으면 GPL 공개 의무는 발생하지 않습니다. 제품 출시·앱 배포·기기 판매 시 폭발.
- **AGPL의 함정**: 배포하지 않고 **웹서비스로 제공만 해도** 이용자에게 소스 공개 의무 → **SaaS 회사엔 치명적**. (일부 DB·라이브러리가 AGPL)

해야 할 것

의존성 추가 **전에 라이선스부터 확인**. GPL/LGPL/AGPL/SSPL이 보이면 **임의로 넣지 말고 팀 리드·법무에 확인**. SaaS 프로젝트는 **AGPL을 특히 경계**. "사내 도구로만 쓰지 / 제품에 넣어 배포할지"를 명확히 기록.

③ AI 생성 코드(Copilot·ChatGPT 등) **높음** (최신·일부 미확정)

리스크	내용	대응
라이선스 오염	AI가 학습한 GPL 등 코드를 그대로 출력해 라이선스가 딸려올 수 있음	Copilot "공개 코드 일치 차단" 필터 ON, 생성된 통짜 코드는 기존 OSS 중복 검사
저작권 미확정	순수 AI 생성물은 저작권 보호가 약함(한·미 당국: 인간 창작 기여 필요) → 경쟁사가 베껴도 방어 약할 수 있음	핵심 경쟁력 코드는 AI에 전적으로 의존하지 말고 인간 기여를 남김
보안 취약점	연구상 AI 생성 코드의 상당수가 취약점 포함(연구별 40%대 보고). SQL 주입·XSS·하드코딩 키 등	AI 코드도 사람 리뷰 + 보안 스캔(SAST) 필수. "AI가 짰으니 안전"은 틀림
기밀 입력	①번과 동일 — 가장 치명적	기밀·PII 입력 금지

④ 타인 코드 복붙 — SO·블로그·전 직장 코드 중간

- **Stack Overflow 코드는 CC BY-SA**(출처 표시 + 동일조건 재배포) → 상당 분량을 독점 제품에 넣으면 충돌 가능. (짧은 관용 스니펫은 위험 낮음)
- **블로그·튜토리얼 코드**: 라이선스 명시 없으면 저작권은 작성자에게. "인터넷에 있으니 공짜"가 아님.
- **전 직장·타사 코드 반입은 절대 금지** — 저작권 + 영업비밀 침해로 **회사가 피소**됩니다.

⑤ 관대한 라이선스도 '고지 의무' 위반이면 침해 중간

MIT·BSD·Apache-2.0도 **저작권 고지 + 라이선스 전문 포함**이 필수입니다. 배포 제품에 **오픈소스 고지 (LICENSE-THIRD-PARTY-NOTICES)** 파일을 두고, 소스 헤더의 저작권·라이선스 주석을 **지우지 마세요**. (앱 설정화면의 "오픈소스 라이선스"가 그것)

4-3. 실무 대응 체계 — 사람 주의만으로 부족, 자동 게이트로

영역	도구·방법
의존성·라이선스 점검(SCA)	SBOM (SPDX·CycloneDX) + ScanCode·FOSSA·Snyk·Black Duck. CI에 라이선스 정책 게이트 (GPL/AGPL 유입 시 빌드 경고/실패)
취약점(CVE) 점검	Dependabot·Snyk·Trivy·OWASP Dependency-Check로 의존성 CVE 자동 감지·업데이트
고지 파일 관리	배포물에 LICENSE-THIRD-PARTY-NOTICES 포함, Apache NOTICE 전파
사내 AI 정책	승인 도구만 허용, 기밀·PII 입력 차단(DLP), 생성 코드도 리뷰·스캔 의무화

논쟁 중 / 미확정 — 단정 금지

- ① **동적 링크가 GPL '파생물'인가**는 확정 판례가 부족해 논쟁 중(보수적으로 대응·법무 확인). ② **AI 생성 코드의 라이선스 책임·저작권 귀속**은 관련 소송(예: GitHub Copilot 소송)·정책이 진행 중으로 미확정. → 애매하면 반드시 **팀·법무 확인**.

마무리 — 통합 체크리스트 & 출처

출시 전 최소 점검 체크리스트

- ☐ 개인정보 수집 동의를 **목적별로 분리**했고, 필수/선택을 나눴다 (선택 미동의로 가입 막지 않음)
- ☐ 개인정보 **처리방침**을 작성해 화면 하단에 상시 노출했다 (이용약관과 별도)
- ☐ 비밀번호는 **일방향 해시**, 민감정보는 암호화, 전 구간 **HTTPS**, 접속기록 보관을 적용했다
- ☐ 주민등록번호를 수집하지 **않는다** (본인확인만 대체수단)
- ☐ **유출 대응 절차**(72시간 통지·신고, 담당자, 템플릿)를 준비했다
- ☐ 마케팅 알리는 **사전 동의 + (광고)표시 + 수신거부**를 갖췄다
- ☐ 돈을 받는다면 **사업자등록·통신판매업 신고·PG·환불정책·세금**을 확인했다 (2장)
- ☐ 채팅/만남 기능이 있다면 **연령확인·불법물 신고차단·모더레이션** 체계를 갖췄다 (3장)
- ☐ 모든 의존성의 **라이선스**를 확인했고 GPL/AGPL 유입을 점검했다 + **오픈소스 고지 파일**이 있다
- ☐ **기밀·소스·개인정보**를 외부 AI에 입력하지 **않는다** (사내 정책 준수)

마지막 당부

이 체크리스트는 **출발점**일 뿐입니다. 서비스 성격·규모에 따라 의무가 달라지고, 법은 계속 바뀝니다. **애매하면 반드시 최신 원문(law.go.kr)과 소관 기관·전문가에게 확인**하세요. 특히 **개인정보보호법 2026-09-11 개정** 시행 내용은 시행 전후로 꼭 다시 보세요.

공식 출처 · 기관 (북마크 권장)

분야	기관 / 사이트
법령 원문	법제처 국가법령정보센터 law.go.kr · 찾기 쉬운 생활법령 easylaw.go.kr
개인정보	개인정보보호위원회 pipc.go.kr · 유출신고 brss.pipc.go.kr · 개인정보포털 privacy.go.kr
보안·인증	한국인터넷진흥원 KISA kisa.or.kr · ISMS-P isms-p.or.kr
거래·소비자·광고	공정거래위원회 ftc.go.kr · 소비자24 consumer.go.kr
세금	국세청 nts.go.kr · 홈택스
방송통신·위치정보	방송통신위원회 kcc.go.kr · 위치정보지원센터 lbsc.kr
오픈소스·저작권	공개SW 포털 oss.kr · 한국저작권위원회 copyright.or.kr

본 자료는 공개된 법령·공식 기관 자료를 바탕으로 여러 단계의 조사·교차검증을 거쳐 작성한 **교육용 개요**이며, 법률자문이 아닙니다. 수차·기준·최신 개정 여부는 반드시 위 공식 출처로 재확인하시기 바랍니다. 기준 시점: 2026년 7월.

대상: 인턴·초급 개발자 · 서비스 개발/운영 법·규제 입문